

Clase 287 — Métricas de seguridad: KPIs y KRIs

Parte: **14 — GRC, riesgo y cumplimiento** · Fuente: *How to Measure Anything in Cybersecurity Risk (Hubbard & Seiersen)* 🕒 Duración estimada: **90 min** · Nivel: **Intermedio**

🎯 Objetivo

Aprender a medir la seguridad con indicadores que impulsen decisiones: KPIs (rendimiento), KRIs (riesgo) y KCIs (control). Al terminar sabrás diseñar métricas SMART, distinguir un indicador accionable de una "vanity metric", construir un cuadro de mando (dashboard) para la dirección y evitar el error de medir lo fácil en vez de lo importante.

📊 Resultados de aprendizaje

Al finalizar, el alumno podrá:

- 1. **Distinguir** KPI, KRI y KCI y cuándo usar cada uno.
- 2. **Diseñar** métricas SMART, con fuente de dato, umbral y responsable.
- 3. **Diferenciar** métricas accionables de métricas de vanidad.
- 4. **Construir** un cuadro de mando de seguridad para dirección.
- 5. **Calcular** métricas operativas clave (MTTD, MTTR, cobertura de parches).

📖 Temas

#	Tema	Por qué importa
1	Por qué medir	Sin medida no hay mejora ni presupuesto
2	KPI vs. KRI vs. KCI	Cada uno responde a una pregunta distinta
3	Métricas SMART y umbrales	Que sean accionables
4	Métricas operativas (MTTD, MTTR)	Miden la eficacia de detección/respuesta
5	Vanity metrics	Lo que parece útil pero no lo es
6	Cuadros de mando por audiencia	Dirección vs. equipo técnico
7	Cadencia y tendencia	El valor está en la evolución

📖 Definiciones y características

- **KPI (Key Performance Indicator):** mide el rendimiento hacia un objetivo. *Clave:* mira lo que ya pasó/está pasando (retrospectivo).
- **KRI (Key Risk Indicator):** señala aumento de exposición al riesgo antes de que se materialice. *Clave:* predictivo, alerta temprana.
- **KCI (Key Control Indicator):** mide la eficacia de un control. *Clave:* ¿el control funciona como se espera?

- **MTTD (Mean Time To Detect)**: tiempo medio en detectar un incidente. *Clave*: menor es mejor; mide visibilidad.
- **MTTR (Mean Time To Respond/Recover)**: tiempo medio en responder o recuperar. *Clave*: mide la eficacia de la respuesta.
- **Vanity metric**: número que impresiona pero no guía decisiones (p. ej. "bloqueamos 2M de ataques"). *Clave*: evítala en informes de decisión.
- **Umbral (threshold)**: valor que dispara una acción. *Clave*: convierte una métrica en un semáforo accionable.

Herramientas y preparación

- Hoja de cálculo o herramienta de BI (Grafana, Metabase, Power BI) para el dashboard.
- Fuentes de datos: exportaciones de SIEM, gestor de vulnerabilidades, IAM, ticketing (reutiliza herramientas de partes previas).
- Referencia: *CIS Controls Measures & Metrics*, *NIST SP 800-55* (Performance Measurement) y el enfoque de Hubbard sobre medición.
- Plantilla de ficha de métrica: nombre, tipo (KPI/KRI/KCI), fórmula, fuente, umbral, responsable, cadencia.

Laboratorio guiado (ejercicio aplicado)

Vas a construir el cuadro de mando de seguridad de "Ferretería del Sur S.A.".

1. **Inventario de preguntas**: escribe las 5 preguntas que la dirección se hace ("¿estamos más seguros que hace 3 meses?", "¿respondemos rápido?", "¿cumplimos parches?"). Las métricas responderán a estas preguntas, no al revés.
2. **Diseña 8 métricas** con su ficha completa. Ejemplos: - KPI: % de sistemas con parches críticos aplicados en < 30 días (umbral $\geq 95\%$). - KRI: nº de vulnerabilidades críticas abiertas > 30 días (umbral ≤ 5). - KCI: % de accesos con MFA activo (umbral 100%). - Operativa: MTTD y MTTR de incidentes del último trimestre. - Humana: tasa de reporte de phishing (de la clase 286).
3. **Calcula** dos de ellas con datos de ejemplo. Ej.: $MTTR = \text{suma de tiempos de resolución} / \text{nº de incidentes}$.
4. **Define umbrales y semáforos**: verde/ámbar/rojo para cada métrica.
5. **Detecta vanity metrics**: revisa tu lista y descarta o reformula cualquier métrica que no guíe una decisión (p. ej. "nº total de eventos del SIEM").
6. **Cuadro de mando**: maqueta un dashboard de una página para dirección (5–6 métricas con tendencia y semáforo) y otro más detallado para el equipo técnico.
7. **Narrativa**: escribe el párrafo de 4 líneas que acompañaría el dashboard en el comité mensual: qué mejoró, qué empeoró y qué se pide.

Ejercicios

1. Clasifica en KPI, KRI o KCI: % de cuentas con MFA; nº de accesos de administrador anómalos; días desde el último parche crítico pendiente.
2. Reformula la vanity metric "bloqueamos 2 millones de ataques" en una métrica accionable.
3. Calcula el MTTR dado un conjunto de 5 incidentes con sus tiempos.
4. Define umbrales verde/ámbar/rojo para "cobertura de EDR en endpoints".
5. Diseña una métrica SMART para medir la eficacia del programa de concienciación.

6. Explica por qué la tendencia importa más que el valor absoluto.

Reto verificable

Entrega un **cuadro de mando de seguridad** con al menos 8 métricas (mezcla de KPI, KRI y KCI), cada una con ficha completa (fórmula, fuente, umbral, responsable, cadencia), dos métricas calculadas con datos de ejemplo, semáforos definidos, y una narrativa ejecutiva de acompañamiento.

Criterio de aceptación: cada métrica responde a una pregunta de negocio, ninguna es una vanity metric, todas tienen umbral y responsable, y el dashboard de dirección cabe en una página con tendencias.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Medir lo fácil, no lo importante	Sesgo del dato disponible; parte de las preguntas de negocio
Vanity metrics en el informe de dirección	Impresionan pero no deciden; sustituye por accionables
Métricas sin umbral	No accionan; añade semáforos verde/ámbar/rojo
Reportar valor absoluto sin tendencia	Se pierde el contexto; muestra evolución temporal
Un dashboard único para todos	Dirección y técnicos necesitan detalles distintos; segmenta

Preguntas frecuentes

? ¿Cuál es la diferencia esencial entre KPI y KRI? El KPI mira el rendimiento pasado/actual (retrospectivo); el KRI anticipa un aumento de riesgo (predictivo). Un buen cuadro de mando combina ambos.

? ¿Cuántas métricas debe ver la dirección? Pocas y potentes: 5–7 con tendencia y semáforo. El detalle operativo va en un dashboard técnico aparte.

? ¿MTTD y MTTR de dónde salen? De los tickets/registros de incidentes: marca de tiempo de origen, detección y resolución. La calidad del dato depende de un buen registro de incidentes.

? ¿Cómo evito las vanity metrics? Pregunta por cada métrica: "¿qué decisión cambiaría si este número sube o baja?". Si la respuesta es "ninguna", elimínala.

Referencias

- Hubbard & Seiersen — How to Measure Anything in Cybersecurity Risk. <https://www.howtomeasureanything.com/cybersecurity/>
- NIST SP 800-55 Rev.2 — Measurement Guide for Information Security. <https://csrc.nist.gov/pubs/sp/800/55/r2/final>
- CIS Controls — Measures and Metrics. <https://www.cisecurity.org/controls>
- Grafana / Metabase (dashboards). <https://grafana.com/>
- (ISC)² CISSP Official Study Guide, dominio 1.

Siguiente clase

Clase 288 - Seguros ciberneticos